

Lab 10 - Advanced Phishing Investigation

Header Review, Authentication Analysis, IOC Extraction, and Blast-Radius Assessment

Attribute	Details
Scenario	Safe simulated Microsoft 365 phishing email
Verdict	Phishing / malicious
Severity	High
Escalation	Yes

1. Scenario

Field	Observed value
Subject	Urgent: Microsoft 365 Account Suspension Notice
From	Microsoft Security <security-alert@microsoft-support.com>
Reply-To	support-team@account-verification-help.com
Return-Path	<bounce@microsoft-support.com>
Verification URL	https://microsoft-security-check.example-login.com/verify
SPF / DKIM / DMARC	Fail / None / Fail

2. Suspicious Indicators

- From and Reply-To use different domains.
- Urgent account-suspension language pressures the user to act quickly.
- SPF failed, DKIM was absent, and DMARC failed.
- microsoft-support.com uses the digit 0 in a lookalike domain.
- The registrable verification domain is example-login.com, not Microsoft.

3. IOC Table

IOC Type	Value
Sender domain	microsoft-support.com
Reply-To domain	account-verification-help.com
Verification domain	example-login.com
Verification path	/verify

4. Blast-Radius Questions

- Did other users receive the same message?
- Did anyone click the link?
- Did anyone submit credentials?
- Are matching messages still present in mailboxes?

5. Recommended SOC Response

- Block sender/domain and malicious URL indicators.
- Search the email environment for matching messages.
- Remove matching messages where possible.
- Review click telemetry and affected-user sign-ins.
- Reset credentials and review MFA if credential submission is suspected.
- Document IOCs for future detection and threat hunting.

6. Analyst Conclusion

The message was classified as high-severity phishing based on independent indicators: lookalike sender infrastructure, sender/Reply-To mismatch, failed authentication checks, urgent social-engineering language, and a non-Microsoft verification destination. In this simulated exercise, no click, credential submission, or account compromise was confirmed.

7. Safety Note

The lab used a simulated phishing sample only. No live phishing infrastructure, malicious attachment, or credential-harvesting page was accessed.